

# System Specific Policy of Modisoft for Ransomware

Semir Hot, Harrison Maksimik

March 10, 2024

## Contents

|          |                                  |          |
|----------|----------------------------------|----------|
| <b>1</b> | <b>Statement of Policy</b>       | <b>1</b> |
| 1.1      | Purpose . . . . .                | 1        |
| 1.2      | Scope . . . . .                  | 1        |
| 1.3      | Responsibilities . . . . .       | 1        |
| 1.4      | Definitions . . . . .            | 2        |
| 1.5      | Background . . . . .             | 2        |
| <b>2</b> | <b>Security Concerns</b>         | <b>2</b> |
| 2.1      | General Considerations . . . . . | 2        |
| 2.2      | Threat of Ransomware . . . . .   | 2        |
| <b>3</b> | <b>Security Controls</b>         | <b>3</b> |
| 3.1      | Access control . . . . .         | 3        |
| 3.2      | Authentication . . . . .         | 3        |
| 3.3      | Regular maintenance . . . . .    | 3        |
| <b>4</b> | <b>Scheduled Reviews</b>         | <b>4</b> |

## 1 Statement of Policy

### 1.1 Purpose

The purpose of this policy is to provide a set of procedures that should be implemented to better protect the Modisoft application and its associated data. The risk of a ransomware infection on Modisoft's infrastructure poses a great threat to our organization's ability to do business. Therefor, it is

necessary through this policy that considers and mitigates the impact of denial of service and breach of confidentiality that may result from ransomware attacks.

## **1.2 Scope**

The scope of this system-specific policy extends only to the Modisoft application, all data associated with Modisoft, and any employee, contractor, or third party worker who works on or uses the Modisoft application or data. This particular document analyzes only the impacts and mitigations related to ransomware, additional security controls should be found in other documents.

## **1.3 Responsibilities**

It should be the responsibility of the CISO to respond to new business needs not considered in this document, and to keep this document up-to-date. System administrators, contractors and other qualified personnel, along with third-party workers, should be responsible for the implementation of the listed security measures. All other employees and workers should be responsible for following the spirit of this document; it should not be acceptable to circumvent the security controls implemented as described in this document. Should new business needs conflict with these controls, a notice containing relevant details should be sent as soon as possible to the employee's line manager, other information security personnel, or the CISO via email.

## **1.4 Definitions**

- POS: point of sale.

## **1.5 Background**

Modisoft is the new application that we brought into the business to help management better control and view of what is happening in the business, and to ensure that we are aware of what is going on even when we are not in the building. Through this application, management is able to see all sales, inventory, sales and new stock. Modisoft also has the ability to change pricing on the fly locally and send that change to the POS system. Lower privileged employees are able to view certain aspects of the finances without having access to any sensitive data.

## 2 Security Concerns

### 2.1 General Considerations

If an attacker gains access to the management login within this application, they will be able to see what sales are done, change the pricing of items, and disable other basic functions of the application, such as the inventory system. This would lead to major disruption to our business operations.

### 2.2 Threat of Ransomware

Additionally, because Modisoft is connected to our organization's network, it remains a potential attack vector for a ransomware attack. If Modisoft is compromised, it's possible that the infection could be spread throughout the network should network-based security controls fail. Therefore, this policy seeks to find methods of hardening Modisoft itself, and also to reduce damages and spread of ransomware should these security controls be breached.

## 3 Security Controls

### 3.1 Access control

While Modisoft contains some built-in access control using traditional username and password authentication, our long-term security policy for this application should include a more robust access control policy that can scale as our organization continues to segregate duties between communities of interest. This security control will also help reduce the spread of ransomware and other malware in our system by giving the least privileges required for all users, preventing access to unnecessary resources; the classification of resources as necessary and unnecessary should be done at authentication time using this robust access control method, meaning users will only be permitted to access a certain subset of the resources they are privileged to in a certain session. The implementation details of this access control model should be defined in a separate system-specific policy for our organization's *next access control model*.

### 3.2 Authentication

A password policy for the users of this application is the best way to mitigate disruptions. Requirements for the complexity of the passwords should

be defined in a system specific policy for password management, as password requirement change frequently. This is an important step to securing our organization from the threat of ransomware, as Modisoft is a network-connected application.

### **3.3 Regular maintenance**

Modisoft is a contractor-built tool which will need regular maintenance and security audits. While the current state of Modisoft is functional for our organization's needs, it remains important that new business needs are met, and more critically, that security patches are merged into our organization's deployment of Modisoft in a timely manner - both for the application itself, and infrastructure technology that the application relies on. Maintenance should be scheduled annually, and security audits should be scheduled similarly, or, as costs permit, bi-annually. It should be the job of the CISO to establish the scheduling of this maintenance at the beginning of each fiscal year.

## **4 Scheduled Reviews**

This policy should be reviewed by the CISO and other parties of interest on an annual basis. New technologies may make the current security controls obsolete in the future; each of the provided guidelines under the *Security Controls* section should be carefully reviewed during this time.